

# VIGIL: Developer & Engineering Blueprint

Technical Implementation Blueprint for AI Tier-1 SOC Analyst for Indian BFSI

## 1. Executive Summary & Core Architectural Tenets

Under CERT-In Directions (April 2022) and the RBI Cyber Security Framework, Indian banks must detect, investigate, contain, and report material cyber incidents within a mandatory 6-hour regulatory window. VIGIL bridges Alert Zero (triage) to Filing Zero (compliance) by converting Attack Discovery narratives into rupee-quantified business risk, drafting CERT-In Annexure-1 reports in under 10 minutes, and sealing evidence into an immutable SHA-256 hash-chained ledger.

## 2. System Architecture & Component Interaction Flow

| ARCHITECTURE PIPELINE       |     |                                                                |
|-----------------------------|-----|----------------------------------------------------------------|
| [1. Ingestion (ECS)]        | --> | [2. Elastic Search AI Core] --> [3. Vigil 6-Step Orchestrator] |
| - UPI/IMPS Gateway Logs     |     | - Unified ECS v8.11+ Index                                     |
| - Core Banking CRM Accounts |     | - Elastic ML Anomaly Baseline                                  |
| - Elastic Defend Endpoint   |     | - Attack Discovery Triage Agent                                |
| - NetFlow & CERT-In CIAD    |     | - Piped ES QL Query Engine                                     |
|                             |     | - Step 1: Materiality Classifier                               |
|                             |     | - Step 2: ES QL Evidence Query                                 |
|                             |     | - Step 3: INR Financial Exposure                               |
|                             |     | - Step 4: Containment (HITL Gate)                              |
|                             |     | - Step 5: CERT-In Form & Sarvam                                |
|                             |     | - Step 6: SHA-256 Ledger Sealing                               |

## 3. Telemetry & ECS Schema Specification (BFSI Extensions)

All banking and cyber telemetry conforms to Elastic Common Schema (ECS v8.11+), augmented with custom BFSI fields under 'bank.\*':

| ECS Field           | Type    | Example Value                      | Description                                      |
|---------------------|---------|------------------------------------|--------------------------------------------------|
| @timestamp          | date    | 2026-09-02T19:24:00.120Z           | Event occurrence timestamp (ISO 8601)            |
| event.category      | keyword | network, authentication, financial | High-level event classification                  |
| source.ip           | ip      | 198.51.100.44                      | Source IP of the transacting client / attacker   |
| user.name           | keyword | svc_payment_gw                     | Authenticated identity or service account        |
| bank.account_id     | keyword | ACC-CORP-9921448                   | Core banking primary account identifier          |
| bank.customer_tier  | keyword | Corporate / HNI / Retail           | Account priority & regulatory weighting tier     |
| bank.upi_vpa        | keyword | merchant.bulk@yesbank              | UPI Virtual Payment Address of transacting party |
| bank.amount_inr     | float   | 18240000.00                        | Rupee value of transaction or settlement batch   |
| bank.aml_risk_score | float   | 92.5                               | Real-time AML velocity & anomaly score (0-100)   |

4. Five Ground-Truth Attack Scenarios (30-Day Evaluation Corpus)

|                                                                                                                                                                                          |                                                                |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------|
| <b>Scenario 1: Privileged Token Theft &amp; Bulk UPI Payout</b><br>Adversary compromises API Gateway -> Steals OAuth2 bearer token for svc_payment_gw -> Injects unauthorized corporat   | <b>CRITICAL   Exp: Rs. 1,82,40,000   RBI: MANDATORY</b>        |
| <b>Scenario 2: Distributed NetBanking Credential Stuffing</b><br>Tor/VPN botnet executes 4,200 req/min credential stuffing attack against /api/v2/netbanking/login -> Compromises 28     | <b>HIGH   Exp: Rs. 42,50,000   RBI: MANDATORY</b>              |
| <b>Scenario 3: ATM Switch ISO 8583 Response Code Manipulation</b><br>Lateral movement in branch network -> ARP poisoning on ATM switch router -> Modifies ISO 8583 response codes from 5 | <b>CRITICAL   Exp: Rs. 3,40,000   RBI: MANDATORY</b>           |
| <b>Scenario 4: Rogue Branch Insider KYC Tampering</b><br>Branch loan officer terminal used off-hours -> Modifies KYC verification flag on 12 unapproved loan applications ->             | <b>HIGH   Exp: Rs. 28,00,000   RBI: MANDATORY</b>              |
| <b>Scenario 5: Benign Month-End Batch Rebalancing</b><br>Scheduled monthly corporate interest calculation batch generates high CPU load and 50k ledger transactions at 02:00             | <b>BENIGN   Exp: Rs. 0 (Auto-Filtered)   RBI: NOT REQUIRED</b> |

5. ES|QL Forensic Query Catalogue

Vigil leverages modern ES|QL piped queries for sub-second evidence retrieval and blast radius quantification:

```
QUERY 1: ATTACKER IP BLAST RADIUS ACROSS AUTH & UPI
FROM logs-*
| WHERE source.ip == "198.51.100.44"
| KEEP @timestamp, event.category, user.name, bank.upi_vpa, bank.amount_inr, http.response.status_code
| SORT @timestamp asc
| LIMIT 100

QUERY 2: FINANCIAL RISK AGGREGATION BY CUSTOMER TIER
FROM logs-banking-*
| WHERE event.type == "transaction" AND bank.batch_id == "BATCH-20260902-8821"
| STATS total_amount_inr = sum(bank.amount_inr), tx_count = count(), avg_aml = avg(bank.aml_risk_score) BY bank.customer_tier
| SORT total_amount_inr desc
```

6. The 6-Step Deterministic Agentic Workflow Deep Dive

- Step 1 (Materiality & RBI Thresholds): Evaluates Attack Discovery narrative against RBI Master Direction thresholds (fund diversion > Rs. 5 Lakhs, core banking outage > 15m). Emits materiality flag and 6-hour regulatory countdown.
- Step 2 (ES|QL Grounded Evidence): Executes piped queries across auth, network, and banking logs. Extracts exact indicators of compromise (IoCs), compromised credentials, and raw ECS document IDs.
- Step 3 (INR Business Risk Exposure): bank.exposure.lookup tool queries Core Banking CRM: computes Direct Loss (Rs. 1.82 Crore) + Customer Blast Radius (14 HNI, 4 Corp) + RBI Regulatory Penalty Risk (Rs. 1.00 Crore).
- Step 4 (Containment & HITL Approval): Recommends actionable containment (Revoke OAuth2 token #8821, null-route IP, freeze UPI batch). Renders 1-click Human-in-the-Loop authorization gate before executing.
- Step 5 (CERT-In Annexure-1 Report): certin.report.draft formats official 8-point statutory report (Incident chronology, impacted systems, remedial actions). Sarvam AI translates executive brief into 22 Indic languages.
- Step 6 (Cryptographic Evidence Sealing): evidence.ledger.append SHA-256 hash-chains all telemetry, LLM reasoning, queries, and approvals into S3 Object Lock (WORM) storage with AWS KMS signing.

7. Complete REST API & WebSocket Specification

| Method | Endpoint                     | Functionality                         | Payload Summary                                                 |
|--------|------------------------------|---------------------------------------|-----------------------------------------------------------------|
| GET    | /api/incidents               | List validated attack narratives      | Returns active incidents with severity & INR exposure           |
| GET    | /api/incidents/{id}          | Get full incident state & workflow    | Returns active step, queries, timeline, and exposure card       |
| POST   | /api/incidents/{id}/step/{n} | Execute specific workflow step        | Executes Step 1 to 6 with LLM reasoning & tools                 |
| POST   | /api/hitl/approve            | Human analyst containment approval    | Payload: { incident_id, analyst_id, decision: APPROVE }         |
| POST   | /api/esql/execute            | Run custom ES QL piped query          | Payload: { query: 'FROM logs-*   ...' } -> Returns rows         |
| GET    | /api/reports/certin/{id}/pdf | Download official CERT-In PDF         | Returns formatted application/pdf statutory report              |
| POST   | /api/translate/indic         | Translate brief via Sarvam AI         | Payload: { text, target_lang: 'hi' } -> Indic text              |
| GET    | /api/ledger/verify           | Verify cryptographic hash chain       | Returns: { valid: true, total_blocks: 104, chain_intact: true } |
| WS     | /ws/live-stream              | Real-time incident & countdown stream | Emits WebSocket events on alert arrival & timer ticks           |

8. Frontend SOC Cockpit UI & Component Architecture

The analyst console provides a real-time dark-themed cyber defense cockpit designed for BFSI security operations:

| Component             | Key Functionality                                                          | Tech Stack            |
|-----------------------|----------------------------------------------------------------------------|-----------------------|
| Header & Countdown    | Live 6-Hour Regulatory Clock countdown timer & Alert Zero status badge     | React, Lucide Icons   |
| Incident Stream       | Validated Attack Discovery narratives with FP suppression indicator        | Framer Motion, SSE    |
| INR Exposure Card     | Real-time counter of direct financial risk & HNI/Corporate blast radius    | Tailwind CSS, Cards   |
| Workflow Stepper      | Interactive 6-step timeline with reasoning logs & ES QL viewer             | React Stepper         |
| HITL Approval Modal   | 1-Click authorization of token revocation and payment batch freeze         | Modal Dialog          |
| CERT-In Report Viewer | Official Annexure-1 form renderer with 1-click PDF download & Indic toggle | ReportLab, Sarvam API |

9. Developer Setup & Dual-Mode Execution

SETUP COMMANDS (DUAL-MODE: ZERO CLOUD KEYS REQUIRED)

```
# 1. Backend Setup (Python 3.11)
cd backend && python3.11 -m venv venv && source venv/bin/activate
pip install fastapi uvicorn pydantic reportlab cryptography httpx
python main.py # Launches at http://localhost:8000 (Swagger docs at /docs)

# 2. Frontend Setup (Node 22 / Vite)
cd frontend && npm install && npm run dev # Launches UI at http://localhost:5173
```

10. Team Task Allocation & Hackathon Milestones

| Phase       | Focus Area          | Key Deliverables                                           | Owner                  |
|-------------|---------------------|------------------------------------------------------------|------------------------|
| Milestone 1 | Data & Elastic Core | 30-Day ECS banking corpus + ES QL query catalogue          | Lead Elastic Architect |
| Milestone 2 | Backend & Workflow  | 6-Step FastAPI orchestrator + bank.exposure.lookup         | Backend / Bedrock Lead |
| Milestone 3 | Frontend & UX       | Dark-themed SOC Cockpit UI + 6-hour countdown timer        | Frontend / UX Lead     |
| Milestone 4 | Compliance & AI     | CERT-In PDF exporter + Sarvam Indic + SHA-256 Ledger       | Compliance / AI Lead   |
| Milestone 5 | Grand Finale Demo   | End-to-end 90-sec live attack simulation & pitch rehearsal | Entire Team            |